

### 별표 3 모바일 앱 보안약점 점검기준

| 번호 | 보안약점명                         | 설명                                                                       |
|----|-------------------------------|--------------------------------------------------------------------------|
| 1  | SQL 삽입                        | 검증되지 않은 외부 입력값이 SQL 쿼리문 생성에 사용되어 악의적인 쿼리가 실행될 수 있는 보안약점                  |
| 2  | 경로조작 및 자원삽입                   | 검증되지 않은 외부 입력값이 시스템 자원 접근경로 또는 자원제어에 사용되어 공격자가 입력값을 조작해 공격할 수 있는 보안약점    |
| 3  | 크로스사이트 스크립트                   | 검증되지 않은 외부 입력값에 의해 사용자 브라우저에서 악의적인 스크립트가 실행될 수 있는 보안약점                   |
| 4  | 운영체제 명령어 삽입                   | 검증되지 않은 외부 입력값이 운영체제 명령어 생성에 사용되어 악의적인 명령어가 실행될 수 있는 보안약점                |
| 5  | 오버플로우(정수형, 메모리 버퍼)            | 정수값 및 메모리 버퍼의 경계값이 범위를 넘어서는 경우, 프로그램이 예기치 않게 동작될 수 있는 보안약점               |
| 6  | 취약한 암호화 알고리즘 사용               | 중요정보(금융정보, 개인정보, 인증정보 등)를 열람(또는 변경)할 수 있게 하는 보안약점                        |
| 7  | 중요정보 평문 저장                    | 중요정보(비밀번호, 개인정보 등)를 암호화하여 저장하지 않아 정보가 노출될 수 있는 보안약점                      |
| 8  | 중요정보 평문 전송                    | 중요정보(비밀번호, 개인정보 등) 전송시 암호화하지 않거나 안전한 통신채널을 이용하지 않아 정보가 노출될 수 있는 보안약점     |
| 9  | 하드코딩된 비밀번호                    | 소스코드 내에 비밀번호가 하드코딩 되어 소스코드 유출시 노출 우려 및 키 변경이 용이하지 않는 보안약점                |
| 10 | 충분하지 않은 키 길이 사용               | 데이터의 기밀성, 무결성 보장을 위해 사용되는 키의 길이가 충분하지 않아 기밀정보 누출, 무결성이 깨지는 보안약점          |
| 11 | 적절하지 않은 난수값 사용                | 예측 가능한 난수사용으로 공격자로 하여금 다음 숫자 등을 예상하여 시스템 공격이 가능한 보안약점                    |
| 12 | 하드코딩된 암호화 키                   | 소스코드 내에 암호화키가 하드코딩 되어 소스코드 유출시 노출 우려 및 키 변경이 용이하지 않는 보안약점                |
| 13 | 주석문안에 포함된 시스템 주요정보            | 소스코드내의 주석문에 인증정보 등 시스템 주요정보가 포함되어 소스코드 유출시 노출될 수 있는 보안약점                 |
| 14 | 경쟁조건: 검사시점과 사용시점 (TOCTOU)     | 멀티 프로세스 상에서 자원을 검사하는 시점과 사용하는 시점이 달라서 발생하는 보안약점                          |
| 15 | 오류메시지 및 시스템 데이터 정보노출          | 사용자가 볼 수 있는 오류 메시지나 스택 정보에 시스템 내부 데이터나 디버깅 관련 정보가 공개되는 보안약점              |
| 16 | 오류상황 대응 부재                    | 시스템에서 발생하는 오류 상황을 처리하지 않아 프로그램 실행정지 등 의도하지 않은 상황이 발생할 수 있는 보안약점          |
| 17 | 부적절한 예외 처리                    | 예외에 대한 부적절한 처리로 인해 의도하지 않은 상황이 발생될 수 있는 보안약점                             |
| 18 | Null Pointer 역참조              | Null로 설정된 변수의 주소값을 참조했을 때 발생하는 보안약점                                      |
| 19 | 부적절한 자원 해제                    | 사용된 자원을 적절히 해제하지 않으면 자원 누수 등이 발생하고, 자원이 부족하여 새로운 입력을 처리할 수 없게 되는 보안약점    |
| 20 | 취약한 API 사용                    | 취약하다고 알려진 함수를 사용함으로써 예기치 않는 보안위험에 노출될 수 있는 보안약점                          |
| 21 | 안드로이드 애플리케이션 컴포넌트의 부적절한 접근 허용 | 안드로이드 애플리케이션 컴포넌트 설정으로 부적절한 접근이 허용되어 외부의 애플리케이션에 의해 의도치 않게 실행될 수 있는 보안약점 |
| 22 | 민감한 정보 전송을 위한 암시적 intent 사용   | 암시적 intent를 사용하여 민감한 정보가 전송시 도청 및 악성행위 삽입이 가능한 보안약점                      |
| 23 | 접근제어 없이 내·외부저장소 사용            | 내·외부저장소(SD카드 등)에 중요한 정보를 암호화하여 저장하지 않아 정보가 노출되거나 수정이 가능한 보안약점            |
| 24 | 안드로이드의 권한 검사 우회               | 권한이 전혀 없는 호출 프로그램이 응용 프로그램의 권한을 사용하게 되어 권한 검사를 우회할 수 있는 보안약점             |
| 25 | 클래스 로딩 하이재킹                   | 프로그램의 클래스 로드시 검색되는 디렉토리의 이름이 변경되어 클래스 경로를 공격자가 명시적으로 제어할 수 있는 보안약점       |
| 26 | 소스코드 난독화 미적용                  | 역공학 기술에 의한 소스코드 유출 및 보안메커니즘 우회 등이 발생할 수 있는 보안약점                          |